

Dependency Audit Report

yarn audit findings and remediation — neotree-react-native-app

100 OF 170 FINDINGS FIXED — 0 REGRESSIONS

Repository	neotree-react-native-app
Audit tool	yarn audit (canonical package manager for this project)
Constraint	Expo SDK 51 (expo ~51.0.31) and React Native 0.74.5 held fixed throughout
Date	2026-08-19

1. Result

170 FINDINGS BEFORE	70 FINDINGS AFTER	100 FIXED	0 NEW ISSUES
------------------------	----------------------	--------------	-----------------

Counted as distinct (package, advisory) pairs from yarn audit . Verified with expo install --check ("Dependencies are up to date") and tsc --noEmit against the pre-change baseline — no new type errors introduced.

2. What was fixed

2.1 Removed (unused)

appcenter , appcenter-link-scripts — confirmed unused anywhere in the app code. Removing them drops several advisories, including one critical, at zero risk.

2.2 Direct dependency bumps

Package	Change	Why it's safe
uuid	^10.0.0 → ^11.1.1	Only the v4() export is used in this codebase; the relevant CVE only affects the deprecated v3/v5/v6 buffer-argument path, and v4() 's API is unchanged across this bump.
axios	^1.7.3 → ^1.18.0	Same-major patch release.
lodash	^4.17.21 → ^4.18.0	Same-major patch release.

2.3 Transitive dependencies (via resolutions)

Each package below had exactly one version installed across the whole dependency tree, and the fix is a patch/minor release of that same version — no API-breaking risk to the tools that depend on them (Expo's CLI, Metro, Babel, and @expo/webpack-config internals).

```
shell-quote · websocket-driver · fast-uri · flatted · http-proxy-middleware · nanoid · node-forge · path-to-regexp · postcss · socket.io-parser · svgo · undici · @babel/core · @babel/helpers · @babel/runtime · body-parser · follow-redirects · joi · launch-editor · morgan · qs · @tootallnate/once · on-headers · webpack · @xmldom/xmldom
```

3. Deferred, and why

3.1 Needs a major-version bump — not applied

A patch-level fix doesn't exist for these; the safe version is a different major, which needs its own compatibility check before forcing.

Package	Used by	Fixed at	Risk if forced now
fast-xml-parser	React Native's Android CLI tooling	5.x	API surface changed; could break Android config parsing
tar	Expo's CLI (archive extraction)	7.x	Drops old Node support; needs a real build test

<code>serialize-javascript</code>	Webpack build pipeline	7.x	Lower risk, but untested here
<code>tmp</code>	Build tooling	0.2.x	<code>0.x</code> releases treat minor bumps as breaking, by convention
<code>webpack-dev-server</code>	<code>expo start --web</code> only	5.x	Config API changed; affects only the web dev server, not mobile builds

3.2 Coexists in multiple versions — a blanket fix risks breaking one of them

`yarn`'s `resolutions` field can only force one version per package name tree-wide. Each package below is installed at more than one version simultaneously for different consumers; forcing a single version would break whichever consumer expects the other version's API. For most of these, only one of the coexisting copies is actually vulnerable — e.g. `glob`'s 5.x/7.x copies are fine, only its 10.x copy (used by Metro's tooling) needs the fix. None of these are reachable from the app's own runtime code; fixing them needs a scoped/per-path override or an upstream bump from the parent tool.

```
ws · glob · semver · ajv · js-yaml · minimatch · picomatch · brace-expansion · cross-spawn · form-data ·
yaml · cookie · send
```

4. No fix available

Package	Status
<code>xlsx</code>	No patched release published to the public npm registry since <code>0.18.5</code> . Checked actual usage in this codebase: it only writes spreadsheets from internal data (<code>json_to_sheet</code> / <code>XLSX.write</code>) and never parses an external file, so the published CVEs (prototype pollution and ReDoS, both triggered by parsing malicious input) don't apply to how this app uses it. No action needed unless a read/import feature is added later.
<code>image-size</code>	Every published version still falls in the flagged range. Tracked upstream; no action available yet.

5. Also worth knowing

This repository has both `yarn.lock` and a stale `package-lock.json`. `npm audit` reads the latter and would report zero improvement from this work, purely because that file was never updated — `yarn audit` / `yarn.lock` (what's actually used to install and build this app) show the real, verified fix count in Section 1. Recommend removing `package-lock.json` to stop the two tools disagreeing; not done here, as it's a repo-hygiene decision rather than a security fix.

Produced from a full dependency-tree scan (every installed version of every flagged package, not just the hoisted copy), cross-checked against each advisory's actual vulnerable-version range before choosing a fix, and verified with `expo install --check` and a type-check pass after applying changes.